



REPORTE EJECTIVO DE LA EMPRESA

Para: Directorio de la Clínica Privada

Elaborado por: Gabriel Rodríguez (DNI: 46296777)

1. Resumen Ejecutivo

El presente informe presenta la evaluación de riesgos de seguridad de la información llevada a cabo sobre la infraestructura tecnológica de la clínica mediante la plataforma SimpleRisk. Se analizaron activos críticos tales como la Base de Datos de Historias Clínicas (A01), el Servidor Web de Turnos (A02) y la red interna de consultorios (A03). Todos los riesgos detectados se encuentran actualmente bajo una estrategia de planificación de mitigación (*Mitigation Planned*), orientada a reducir la exposición de los datos sensibles de los pacientes y garantizar la continuidad operativa de la institución.

2. Top 5 Riesgos por Nivel

Conforme a la matriz cuantitativa registrada en la plataforma, se priorizan los siguientes hallazgos:

1. **ID 1005 - Brecha de datos masiva por exfiltración de registros médicos en la BD central:** Calificado como **Alto (Inherente: 8.0 / Residual: 8.0)**, con un impacto *Extreme/Catastrophic* sobre la base de datos de historias clínicas.
2. **ID 1001 - Filtración de historias clínicas por falta de controles de acceso:** Calificado como **Medio (Inherente: 4.8 / Residual: 4.8)**, derivado del uso de credenciales genéricas por rol sin autenticación multifactor.
3. **ID 1004 - Estaciones de trabajo de consultorios sin bloqueo de sesión:** Calificado como **Bajo (Inherente: 3.6 / Residual: 3.6)**, debido al riesgo de visualización no autorizada ante ausencias temporales del personal.
4. **ID 1002 - Caída del servidor de turnos por fallo de infraestructura o saturación:** Calificado como **Bajo (Inherente: 3.2 / Residual: 3.2)**, comprometiendo la disponibilidad del servicio online de turnos.
5. **ID 1007 - Falta de actualización y parches de seguridad en el Servidor Web de Turnos:** Calificado como **Bajo (Inherente: 3.6 / Residual: 3.6)**, asociado al rezago operativo en las ventanas de mantenimiento preventivo.

3. Estado de los Planes de Acción

- **Estado Actual:** Los siete riesgos evaluados (IDs 1001 a 1007) se encuentran configurados en estado "**Mitigation Planned**", con responsables asignados (*owners*) pertenecientes a los equipos de *Information Security* e *IT Systems Management*.

- **Soluciones Actuales vs. Requeridas:**

- Para el control de accesos (ID 1001), se planifica migrar de un esquema de contraseña genérica a la implementación obligatoria de **Autenticación Multifactor (MFA)** y cifrado AES-256.
- Para la protección de la base de datos central (ID 1005), se requiere la implementación de respaldos automáticos fuera de línea, inmutables y monitoreo continuo de accesos.
- Para las estaciones de trabajo (ID 1004), se proyecta el despliegue de una Política de Grupo (GPO) para forzar el bloqueo automático a los 5 minutos de inactividad.

4. Recomendaciones Prioritarias

1. **Acelerar la ejecución de mitigación del ID 1005:** Asignar los recursos económicos necesarios (\$100,001 a \$200,000) para blindar la base de datos central de historias clínicas frente a ataques de exfiltración o ransomware.
2. **Implementar MFA y Políticas de Grupo (GPOs):** Aplicar de forma estricta los requerimientos de seguridad definidos para las terminales de los consultorios y los accesos de usuarios (IDs 1001 y 1004).
3. **Automatizar el mantenimiento preventivo:** Formalizar un calendario periódico de aplicación de parches y respaldos para los servidores web y de turnos (IDs 1002 y 1007) a fin de mitigar interrupciones imprevistas.